

Data Protection Impact Assessment (DPIA)

pursuant to Article 35 GDPR

Version 1.0 · April 2026 · Responsible: Bastian Barkowski

1. Executive Summary

This Data Protection Impact Assessment documents the risks and protective measures of the processing of personal data of patients and prospective patients of hair transplant clinics provided by Flowmatix. The processing includes **special categories of personal data** under Art. 9 GDPR (health data) as well as the use of **automated decision-making with AI** (Anthropic Claude), thereby meeting two of the criteria listed in Art. 35(3) GDPR. A DPIA is therefore legally mandatory.

Result: After evaluating all risks and measures, the remaining residual risk is classified as **LOW to MEDIUM**. The processing can be carried out in compliance with the documented technical and organizational measures.

2. Description of Processing

2.1 Controller

The controllers under Art. 4(7) GDPR are the clinic customers of Flowmatix. Flowmatix itself acts as a processor under Art. 4(8) GDPR. This DPIA is prepared by the processor to support its clinic customers in their own compliance obligations.

2.2 Purpose and Legal Basis

Purpose	Legal basis
Patient communication via WhatsApp	Art. 6(1)(b) (contract initiation), Art. 9(2)(h) (healthcare)
Anamnesis / pre-qualification	Art. 9(2)(a) (explicit consent), Art. 9(2)(h)
AI-assisted processing (Claude)	Art. 9(2)(a) (explicit consent with Anthropic disclosure)
Appointment management	Art. 6(1)(b)
Statistics / reporting	Art. 6(1)(f) (legitimate interest)

2.3 Data Categories and Subjects

Master, contact, health, image, appointment, communication and travel data of patients and prospective patients of the respective clinic are processed (see DPA § 3 for the complete list).

2.4 Technical Architecture (summary)

- **Hosting:** Hetzner Online GmbH, Falkenstein/Nuremberg, Germany (ISO 27001)
- **Database:** PostgreSQL 16 with Row-Level Security (RLS), multi-tenant separation per clinic
- **Frontend:** React (Vite), TLS 1.3, Cloudflare CDN/WAF
- **Backend:** Fastify/TypeScript, BullMQ Queue, Redis
- **WhatsApp provider:** 360dialog GmbH (Berlin) → Meta Cloud API
- **AI component:** Anthropic Claude API (Sonnet 4.5), Zero Data Retention API mode
- **Authentication:** JWT with refresh token rotation, optional MFA (TOTP), bcrypt cost factor 12

3. Necessity and Proportionality

3.1 Necessity

Without automated pre-qualification, clinics would have to manually process every patient inquiry — at a typical volume of 50–500 inquiries per day, this would not be economically viable. AI-assisted pre-qualification serves only to prepare medical assessments and does not replace them. Final responsibility for medical decisions remains with the clinic's medical staff.

3.2 Data Minimization

- Only data necessary for pre-qualification and appointment booking is collected.
- Patient photos are only collected in the number requested by the treating physician.
- Sensitive fields (e.g. anamnesis JSON) are pseudonymized/encrypted in the database.
- Message content is sent to Anthropic explicitly without clear identifiers.

3.3 Storage Limitation (Art. 5(1)(e))

The platform implements an automated retention scanner that anonymizes patient data after the configurable retention period (default: 10 years per § 630f BGB) has expired. Patients can request immediate deletion through the CRM at any time (Hard Delete via GDPR Art. 17).

4. Risk Assessment

4.1 Identified Risks

Risk	Likelihood	Severity	Rating
Unauthorized access to patient data	Low	High	Medium
Data loss due to system failure	Very low	Medium	Low
Cross-tenant data leak	Very low	Very high	Medium
Transfer to US sub-processors (Anthropic, Cloudflare)	High (continuous)	Medium	Medium
Faulty AI processing leading to misinformation	Medium	Medium	Medium
Patient withdraws consent — data not deleted	Low	High	Medium
Clinic staff misuses access	Low	High	Medium
Phishing / account takeover of clinic staff	Medium	High	High
Ransomware / extortion	Low	Very high	Medium
Photo upload to Google Drive without clinic awareness	Low (now opt-in)	High	Low

4.2 Risk Mitigation Measures

Access Protection

- Multi-factor authentication (TOTP) available for all clinic accounts — recommendation: mandatory for admin roles
- JWT with short lifetime + refresh token rotation
- Bcrypt cost factor 12 for password hashing
- Rate limiting on login endpoints (5 attempts / 15 min)
- Session revocation on suspicious activity

Tenant Separation

- PostgreSQL Row-Level Security enforces organization_id check at the database level
- Application code uses tenant context (AsyncLocalStorage)
- No BYPASSRLS for the application user

- Code reviews for all changes with RLS impact

Third-Country Transfers (Schrems II)

- EU Standard Contractual Clauses (SCC 2021/914) with all US sub-processors
- Anthropic: Zero Data Retention API mode active — data is not used for training
- Pseudonymization before API call to Anthropic (no direct identifier)
- Cloudflare: only routing/CDN, no content data stored

AI Risks

- Bot is limited to 512 tokens → no hallucination of medical diagnoses
- Strict system prompts prohibiting medical decisions
- Prompt injection protection via wrapping in <patient_message> tags
- On photos-complete: automatic handover to human doctor reviewer
- On aggression / complex questions: automatic handover
- No bot response before explicit GDPR consent

Availability and Recovery

- Daily, weekly, monthly backups with off-site replication
- RTO: 4h, RPO: 24h
- 24/7 monitoring (Grafana, Prometheus, Loki, Uptime Kuma)
- Disaster recovery plan documented and tested annually

Audit Trail

- Complete audit log of all data accesses (Art. 30 GDPR record of processing)
- Read accesses to patient records logged with user, IP, timestamp
- Audit log not deletable by standard users

Data Subject Rights

- Data export endpoint (Art. 15 + 20) — JSON download of all patient data
- Hard delete endpoint (Art. 17) — complete deletion with confirmation
- Consent log documents every consent with timestamp
- Auto-anonymization after retention period

5. Residual Risk Assessment

Category	Before measures	After measures
Confidentiality	High	Low
Integrity	Medium	Low
Availability	Medium	Low
Third-country transfer	High	Medium
AI hallucination	Medium	Low
Overall	High	Low–Medium

6. Consultation of the Supervisory Authority

Since the remaining residual risk is classified as low to medium, prior consultation of the supervisory authority under Art. 36 GDPR is **not required**. The DPIA is documented internally and made available upon request from the supervisory authority or clinic customers.

7. Regular Review

This DPIA is reviewed and updated at least annually or upon material changes to the processing. Material changes include:

- Engagement of new sub-processors
- Change of purposes or data categories
- Change of AI provider or model
- Discovery of new risks (e.g. security vulnerabilities)
- Changes in case law (e.g. Schrems III)

8. Responsibilities

Role	Responsibility
Flowmatix Management	Bastian Barkowski — overall responsibility, DPIA approval
Data Protection Officer	privacy@flowmatix.io
Technical implementation	Engineering Team (Bastian Barkowski)
Flowmatix · Data Protection Impact Assessment · Version 1.0 · April 2026 · privacy@flowmatix.io Sub-processor management	privacy@flowmatix.io

CREATED BY

Bastian Barkowski · Flowmatix

Hude, April 2026

NEXT REVIEW

April 2027

or upon material change